



HECVAT vs 1EdTech TrustEd Apps compliance matrix: map overlap and gaps across data privacy, security, and accessibility rubrics

Computer

Build an edtech roadmap checklist: map 1EdTech TrustEd Apps, HECVAT, and EDUCAUSE 2026 standards into a vendor audit scorecard

Computer

Show me the full compliance scorecard table

Draft a HECVAT mapping for our cloud infrastructure

Add 1EdTech TrustEd Apps rubric criteria

The best way to manage HECVAT, 1EdTech TrustEd Apps, and EDUCAUSE priorities is with one **control library** and three different reporting views. HECVAT is deeper and more operational for university vendor review; 1EdTech adds education-specific trust, interoperability, privacy, accessibility, and generative-AI expectations; EDUCAUSE 2026 helps set strategic priorities such as collaborative cybersecurity and connected campus experience. [¹⁶⁹⁰]

Full compliance scorecard

Use a 0–4 maturity score for each row:

Score	Meaning					
0	Missing, unknown, unsafe, or contradicted by implementation					
1	Policy/design exists, but implementation or evidence is incomplete					
2	Implemented, but manually operated, inconsistently tested, or partially evidenced					
3	Implemented, owned, monitored, tested, and audit-evidenced					
4	Independently tested, automated where appropriate, continuously improved, and transparently reported					
Domain	HECVAT focus	1EdTech TrustEd Apps criteria	EDUCAUSE 2026 priority connection	Semester control objective	Evidence required	Score

Score	Meaning					
---	---	---	---	---	---	---
Corporate governance	Organization, policies, risk, workforce, legal	Public company/policy information and responsible practice	Collaborative cybersecurity	Named executives, RACI, risk appetite, policy review, exception approval	Governance charter, policy register, risk register, review minutes	
Security program	Security management, awareness, audit	Security procedures and technical practices	Collaborative cybersecurity	Security program with tested controls and workforce accountability	Training records, control register, assessment reports	
Asset inventory	Product/infrastructure assets and ownership	System-management practices	Strong data foundations	Inventory cloud accounts, services, repositories, data stores, integrations, endpoints	CMDB/asset inventory, owner list, review log	
Cloud infrastructure	Hosting, network, compute, storage, configuration	Systems management and third-party hosting	Resilient digital services	Segmented, encrypted, monitored, hardened cloud environment	Architecture diagram, IaC, configuration evidence, CSPM report	
Identity and access	Authentication, authorization, privileged access	Authentication and account-management practices	Collaborative cybersecurity	SSO, MFA, least privilege, access review, offboarding, break-glass controls	IAM architecture, MFA policy, quarterly access review, break-glass logs	
Application security	SDLC, secure coding, testing, vulnerabilities	Software-development and maintenance practices	Trustworthy AI and digital services	Threat modeling, CI security gates, code review, dependency/secrets scanning	PR/CI evidence, scan results, threat models, release approvals	
Data encryption	Encryption and key management	Protection of data in transit/at rest	Privacy and trust	Encryption in transit/at rest, managed keys, rotation, secret handling	TLS settings, KMS design, key-rotation record, secret-vault policy	
Tenant isolation	Multi-tenant data separation	Data separation/hosting practices	Trusted ecosystem	Prevent cross-institution, cross-course, and cross-role data access	Authorization tests, RLS policy, penetration-test findings	
Logging and monitoring	Log management, alerting, monitoring	Security monitoring practices	Collaborative cybersecurity	Central audit/security logging with retention, alerting, and investigation	SIEM architecture, sample investigations, alert tests	
Vulnerability management	Scans, patching, penetration testing	Security assessment and response practices	Collaborative cybersecurity	Severity SLAs, scanning, patching, pen tests, tracked exceptions	Scan reports, remediation metrics, pentest summary, exception register	

Score	Meaning					
Incident response	IR plans, notification, testing	Security incident procedures	Resilience and trust	Detect, contain, investigate, notify, learn, and improve	IR plan, tabletop report, postmortems, status template	
Business continuity	Backup, recovery, DR, availability	Operational service reliability	Resilient services	Tested RTO/RPO, restore capability, vendor/key-person contingency	BCP/DR plan, restore test, failover exercise	
Privacy governance	Privacy notices, data processing, PII handling	Data collected, ownership, use, sharing	Student trust/data agency	Data map, purpose limitation, DPA, FERPA controls, privacy requests	Privacy policy, RoPA, DPA, disclosure log, data-flow diagrams	
Retention/deletion	Record lifecycle, disposal, backup handling	Retention/deletion rights and policy clarity	Data governance	Data-class schedule, deletion workflow, backup expiry, legal hold	Retention schedule, deletion test, legal-hold runbook	
Subprocessors	Third-party/vendor management	Hosting/sharing and disclosure	Shared responsibility	Vendor inventory, due diligence, DPAs, ongoing review, exit plan	Subprocessor list, vendor assessments, agreements	
AI governance	AI data, vendor, security, change, risk controls	Gen-AI data rubric: notice, source, provider, ownership, opt in/out	AI literacy and responsible adoption	AI inventory, policy engine, no-training default, evaluation, human oversight	AI policy, provider review, model inventory, evaluation reports	
Accessibility	IT accessibility, conformance, alternatives	Accessibility rubric: documentation, conformance, alternatives/accommodations	Equitable digital access	WCAG 2.2 AA program, ACR/VPAT, testing, remediation, accessible authoring	ACR/VPAT, manual tests, issue tracker, release-gate evidence	
Interoperability	Secure APIs/integrations, data transfers	LTI, OneRoster, QTI, standards/certification	Connected technology ecosystem	Standards-first integrations, versioned APIs, data maps, sandbox and offboarding	Conformance tests, API docs, integration health logs	
Assessment/grade integrity	Product integrity, data accuracy, audit	Trustworthy handling of learner data	Student trust	Versioned rubrics, grade ledger, human approval, reconciliation, appeal	Calculation tests, grade audit sample, change/appeal logs	
Community safety	Privacy, user-generated content, incident handling	Social-interaction data/practices	Connection with trust	Moderation, reports, block/mute, escalation, appeal, limited access	Community policy, training, case audit, retention schedule	
Physical/workforce security	Endpoint, device, facility, HR controls	Company security practice	Shared cyber responsibility	MDM, encryption, secure disposal, onboarding/offboarding, background policy as applicable	MDM reports, asset inventory, HR/offboarding evidence	

Score	Meaning					
Customer assurance	Questionnaire process, audit artifacts	Public transparency and trusted ecosystem participation	Collaborative partnership	Secure procurement room, evidence freshness, customer trust dashboard	HECVAT library, Trust Center, evidence-vault records	

1EdTech describes its Security Practices Rubric as a baseline assessment of supplier policies, procedures, and processes, covering how a company builds and maintains software, handles authentication, and manages services and cloud infrastructure. [^1691]

HECVAT cloud infrastructure mapping

This is a practical cloud-infrastructure mapping, not a substitute for the exact HECVAT 4 question set used by a particular university. Keep the official questionnaire/version in your evidence system and map each item by its actual customer-required identifier.

Cloud area	Control objective	Semester implementation	Evidence artifact	Validation cadence
Account hierarchy	Separate production, staging, development, security/logging, and shared services	Dedicated cloud accounts/projects/subscriptions; organization-level guardrails	Account diagram, policy export, account-owner register	Quarterly/change
Network segmentation	Limit service-to-service and public exposure	Private network segments, security groups/firewalls, private database access, restricted admin ingress	Network diagram, firewall/IaC rules, exposure scan	Continuous/quarterly
Edge protection	Protect web/API endpoints from abuse and common attacks	CDN/WAF, DDoS protection, bot/rate controls, TLS, API gateway	WAF policy, TLS scan, rate-limit configuration, DDoS plan	Continuous/quarterly
Identity	Prevent unauthorized cloud/admin access	Workforce SSO, MFA, short-lived roles, just-in-time privilege, break-glass workflow	IAM policy export, MFA report, access review, break-glass audit	Quarterly
Secrets	Protect credentials, API keys, and integration tokens	Managed secret vault, rotation, scoped service identities, CI secrets scanning	Secret-vault design, rotation logs, scan reports	Continuous/monthly
Encryption	Protect data in transit and at rest	TLS 1.2+ or higher, encrypted databases/object stores/backups, managed keys	Encryption config export, KMS policy, key rotation evidence	Quarterly
Key management	Control encryption-key ownership/use	KMS/HSM-managed keys, separation of duties, key access logs, destruction/rotation process	Key inventory, KMS access logs, rotation test	Quarterly/annual
Compute hardening	Minimize exploitable workload surface	Immutable images, patched base images, workload identity, minimal containers, runtime monitoring	Image scan, patch report, runtime policy	Per build/continuous
CI/CD security	Prevent insecure or unauthorized deployment	Protected branches, peer review, signed artifacts, least-privilege deploy roles, environment approvals	CI config, PR sample, deployment audit log	Every release
Infrastructure as code	Make configuration reviewable and reproducible	Versioned IaC, review gates, policy-as-code, drift detection	IaC repository, plan/apply logs, drift report	Every change
Database security	Restrict and monitor access to academic/student data	Private endpoints, row/tenant controls, parameterized queries, encrypted backups, audited admin access	DB architecture, RLS tests, query/audit logs	Quarterly

Cloud area	Control objective	Semester implementation	Evidence artifact	Validation cadence
Object/file storage	Secure submissions, course content, and exports	Private buckets, signed time-limited access URLs, malware scanning, lifecycle/retention policies	Bucket policy, access-log sample, lifecycle config	Quarterly
Backups	Recover from deletion, corruption, or outage	Encrypted automated backups, cross-zone/region strategy as approved, immutable/recovery copies	Backup config, restore-test evidence, RTO/RPO record	Quarterly
Monitoring	Detect infrastructure and application threats	Central logs, metrics, alerts, SIEM connection, detection rules, on-call process	Monitoring architecture, alert test, incident sample	Continuous/quarterly
Vulnerability management	Find and remediate weaknesses	CSPM, container/image scans, dependency scans, external scans, patch SLAs	Scan reports, ticket metrics, exception approvals	Continuous/monthly
Audit trails	Support investigations and customer accountability	Immutable or protected cloud audit logs, application AuditEvent logs, integration audit records	Log-retention config, sample investigation, integrity controls	Quarterly
Availability	Maintain service during component failure	Health checks, autoscaling, redundancy, graceful degradation, status page	Architecture diagram, failover test, availability report	Quarterly/annual
Regional/residency	Meet contractual and legal location obligations	Tenant region selection where offered, documented data/subprocessor locations, migration process	Region map, data-flow diagram, residency configuration	Onboarding/change
Secure disposal	Remove data and infrastructure securely	Lifecycle expiration, cryptographic deletion where supported, credential revocation, asset disposal controls	Deletion test, key-destruction record, offboarding checklist	Quarterly
Third-party cloud risk	Control cloud-provider and managed-service dependencies	Vendor due diligence, contract/DPA, incident notification, exit strategy	Vendor assessment, contract clauses, cloud exit plan	Annual/change

HECVAT 4 combined prior Full, Lite, and On-Premise variants and added privacy and AI questions, so your cloud-control evidence should be linked to related privacy, AI, product, and accessibility controls rather than treated as a standalone infrastructure exercise. ^[1]

1EdTech TrustEd Apps rubric criteria

Use the exact current rubric version during formal review. Internally, organize readiness around these four evidence streams.

Data Privacy Rubric

Data collected:

- [] Every category, source, purpose, and collection method is inventoried.
- [] Data minimization is implemented and evidenced.
- [] Sensitive and education-record data classes have enhanced controls.

Data ownership and control:

- [] Student/customer ownership and control language is clear.
- [] Sharing is purpose-bound, role-bound, logged, and revocable where applicable.
- [] No sale of student data or undisclosed secondary use.

Deletion and retention:

- [] Retention rules are specific by data class.
- [] Deletion/export/correction processes work in the product.
- [] Backup lifecycle and legal-hold override are documented.

Policy transparency:

- [] Public privacy policy/terms are current, plain-language, versioned, and operationally accurate.
- [] Cookies, analytics, advertising, and third parties are disclosed.
- [] Privacy contact and escalation process are published.

Social interactions:

- [] Community/club/mentorship data use is disclosed.
- [] Visibility, messaging, reporting, moderation, and retention rules are clear.
- [] No undisclosed social-graph analysis or sensitive inference.

Security Practices Rubric

Documentation and company information:

- [] Security contact, policy set, risk ownership, incident process, external assessment posture, and customer-security response process exist.

Data:

- [] Encryption, access control, separation, backup, retention, secure deletion, and sensitive-data handling are documented and tested.

Systems management:

- [] Secure SDLC, patching, vulnerability management, monitoring, logging, authentication, authorization, incident response, and continuity controls operate.

Third-party assessment:

- [] Cloud/subprocessor inventory, due diligence, contractual controls, audit/attestation review, change notification, and exit plan are maintained.

Accessibility Rubric

Information/documentation:

- [] Public and customer documentation is accessible.
- [] Accessibility statement and contacts are published.

Procurement communications:

- [] ACR/VPAT materials are current, evidence-based, and disclose limitations.
- [] Accessibility claims are accurate and versioned.

Conformance:

- [] WCAG 2.2 AA target and test scope are documented.
- [] Student, faculty, admin, and Operations Console journeys are tested.

Alternatives and accommodations:

- [] Core workflows have accessible alternatives.
- [] Accommodation-related settings are privacy-preserving.
- [] Accessibility defects have support, remediation, and communication paths.

Generative AI Data Rubric

Disclosure:

- [] Users can tell when AI is used, what it does, and its limitations.
- [] Source and provider/internal-versus-third-party status are disclosed.

Data use:

- ☐ Training, retention, sharing, and ownership rules are clear.
- ☐ No general-purpose model training on production student/customer data by default.
- ☐ Provider/model inventory and data-flow controls exist.

User choice:

- ☐ Course/tenant-level policy controls exist.
- ☐ Eligible AI history, sharing, and deletion controls are available.
- ☐ Opt-in/out expectations are clear where applicable.

Quality and risk:

- ☐ Bias, accuracy, accessibility, grounding, prompt injection, and misuse tests exist.
- ☐ Human review is required for high-impact outputs/actions.
- ☐ Report, correction, escalation, and incident-response mechanisms exist.

Priority roadmap

P0: Before enterprise pilots

Tenant isolation and authorization test suite
SSO/MFA/privileged-access review
Encryption, secrets vault, secure logging, backups and restore test
Data inventory, DPA, subprocessor inventory, retention/legal-hold/deletion controls
Accessibility design system and critical-path manual testing
AI provider inventory, no-training default, policy engine, evaluation baseline
Incident response and customer-notification runbooks
LTI 1.3 integration test harness and scoped token/key controls

P1: Before broad institutional rollout

HECVAT evidence library and secure procurement room
Current ACR/VPAT and accessibility remediation process
Automated CI/CD security and accessibility release gates
Customer Trust Evidence dashboard
Integration health, reconciliation, and offboarding/export tools
Formal vulnerability disclosure and annual penetration-test program
Faculty/admin change-management and training evidence

P2: Benchmark differentiation

Continuous compliance-control monitoring
Automated evidence freshness/expiry alerts
Tenant-specific policy/data-map dashboard
Public transparency and accessibility/AI change logs
1EdTech interoperability conformance/certification path
Semester Standard annual evidence report
Cross-region/data-residency controls
Independent assurance program, such as SOC 2 if commercially appropriate

Compliance dashboard design

Your dashboard should expose four distinct values—not a single misleading “compliance percentage.”

Implementation:

Is the control built and configured?

Evidence:

Do we have current proof?

Effectiveness:

Has the control been tested and passed?

Risk:

Are there open findings, exceptions, or release blockers?

Dashboard views

Executive:

Top risks, PO/P1 findings, evidence expiry, readiness by framework, customer-impacting gaps.

Engineering:

Release gates, control tests, failed checks, remediation backlog, affected services and owners.

Security/privacy/accessibility/AI:

Control effectiveness, policy status, access review, vendor risk, data-flow changes, test coverage.

Customer:

Approved documents, enabled controls, integration health, retention/AI configuration, planned maintenance, support/SLA status.

Final principle

Universities will not choose Semester because it has a compliance spreadsheet. They choose it when your compliance posture makes their decision safer:

The data map is already clear.
The security answers have evidence.
The accessibility claims are honest.
The AI controls are visible.
The integrations are standards-based.
The implementation path is documented.
The customer can export and offboard.
The operational controls can be audited.

That is how compliance becomes a sales and trust advantage rather than a procurement obstacle.

✱

1. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit/hecvat-faqs-for-corporations>
2. <https://www.1edtech.org/workstream/vetting>
3. <https://www.1edtech.org/standards/accessibility-rubric>
4. <https://www.1edtech.org/standards/security-practices-rubric>
5. <https://www.1edtech.org/standards/data-privacy>
6. <https://www.1edtech.org/standards/ai-rubric>
7. <https://www.1edtech.org/1edtech-trusted-apps-alliance>
8. <https://www.educause.edu/showcase-series/2026/collaborative-cybersecurity>
9. <https://www.1edtech.org/blog/setting-expectations-on-security-practices>
10. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit>

11. <https://er.educause.edu/articles/2025/10/2026-educause-top-10-making-connections>
12. <https://www.1edtech.org/standards/data-privacy/rubric>
13. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit/hecvat-faqs-for-higher-education>
14. <https://www.1edtech.org/program/trustedapps>
15. <https://www.1edtech.org/1edtech-article/new-1edtech-rubrics-provide-valuable-insights-for-educators-selecting-trusted>